

01 GOVERN

CROSS-CUTTING

Create the organizational conditions in which AI risk can be consistently managed.

FOUNDATION

Set the rules

- AI policies, processes and accountability are explicit
- Legal and regulatory requirements are understood and documented
- Risk tolerance determines the level of governance needed

PEOPLE + CULTURE

Build responsibility

- Roles, competencies and decision rights are defined
- Trustworthiness is embedded into organizational practices
- Leadership creates a culture of risk ownership

LIFECYCLE

Control the lifecycle

- Governance spans design, development, deployment and monitoring
- Third-party AI, data and technology dependencies are addressed
- Documentation and transparency support oversight

The governance question:

“Who decides what responsible AI means here — and how do we make that decision enforceable?”

02 MAP

CONTEXT

Understand the AI system in context before deciding how much risk is acceptable.

1

Purpose

What is the system intended to do?

2

Context

Who uses it, where, and under what conditions?

3

Impact

Who could benefit, be harmed, or be affected?

4

Risk

What could go wrong — including misuse and limitations?

SYSTEM

System definition

- Task / model type / capabilities
- Knowledge limits and human oversight
- Data, dependencies and operating environment

SOCIO-TECHNICAL

Stakeholders & impacts

- Users, affected groups and communities
- Benefits, harms and unintended consequences
- Legal, social and organizational expectations

DELIVERABLE

Output of MAP

- A shared risk picture: context + assumptions + requirements + identified risks
- This becomes the input for selecting what must be tested, measured and monitored

03 MEASURE

EVIDENCE

Turn the risks identified in MAP into evidence that can be tested, tracked and challenged.

1 • TEST

Evaluate

- Select methods and metrics for the most significant risks
- Test performance, robustness, safety, security, fairness, privacy and other relevant characteristics
- Use appropriate TEVV approaches

2 • INTERPRET

Analyze

- Examine errors, limitations and failure modes
- Assess whether metrics are appropriate for the use context
- Consider both technical and socio-technical evidence

3 • MONITOR

Track

- Monitor changes over time
- Reassess metrics and control effectiveness
- Document what cannot or will not be measured

Measure is not “collecting metrics.” It is building credible evidence for a risk decision.

04 MANAGE

DECISION

Use the evidence from MAP + MEASURE to prioritize risks and decide what happens next.



FROM ANALYSIS → ACTION

Risk response is a management decision

- High-priority risks should have documented owners, actions, resources and timelines
- Responses can include mitigation, transfer, avoidance or acceptance
- The decision to deploy is itself a risk-management outcome

CONTINUOUS

Close the loop

- Feed new incidents, monitoring results and changed assumptions back into MAP
- Reassess measurement methods as the system and context evolve
- Governance remains active throughout the lifecycle

05 NIST RESOURCES & LINKS

SOURCE OF TRUTH

Use the official NIST AI RMF 1.0 and Playbook as the source of truth.

NIST AI RMF 1.0

Core framework • January 2023

[OPEN](#) 

NIST AI RMF Core

Govern / Map / Measure / Manage overview

[OPEN](#) 

NIST AI RMF Playbook

Suggested actions aligned to the four functions

[OPEN](#) 

Govern

Policies, accountability, culture and lifecycle governance

[OPEN](#) 

Map

Context, stakeholders, system categorization and risks

[OPEN](#) 

Measure

Metrics, TEVV, analysis and monitoring

[OPEN](#) 

Manage

Prioritization, treatment, response and ongoing management

[OPEN](#) 

NIST AI RMF landing page

Current framework status and related profiles

[OPEN](#) 

Important: NIST describes the AI RMF functions as iterative and risk-based — not a rigid checklist or sequence.